APIs & auth · Quick concepts

Interview revision sheet. Read it the evening before, then test yourself in Interview practice.

HTTP and REST

- Methods: GET (read), POST (create), PUT (replace), PATCH (partial update), DELETE.
- Idempotent: GET, PUT, DELETE. POST usually is not.
- Status codes: 400 bad request, 401 unauthenticated, 403 forbidden, 404 not found, 415 wrong Content-Type, 429 rate limited, 500, 502, 503, 504.
- Headers that matter: Content-Type, Accept, Authorization, correlation ID.

SOAP

- XML envelope, header and body; WSDL describes operations; test with SoapUI.

Authentication and authorization

- Authentication = who you are; authorization = what you can do.
- JWT: header.payload.signature; signed, not encrypted; check exp for expiry.
- OAuth 2.0: access tokens for APIs. Flows: authorization code (users), client credentials (server to server).
- Refresh tokens get new access tokens; introspection checks opaque tokens.
- mTLS: both sides present certificates.

Browser specifics

- CORS controls which origins may call an API from a browser; Postman ignores CORS.

Resilience

- Timeouts on every call; retries with exponential backoff and jitter.
- Circuit breakers stop calling failing services.
- Dead letter queues hold failed messages for investigation.
- Rate limiting and throttling at the API gateway.

Integration and middleware

- API gateway: routing, auth, throttling, logging.
- Webhooks: callbacks when events happen (such as Docusign envelope completed).
- TIBCO and similar middleware integrate systems through messaging and services.
- OpenAPI (Swagger) specs describe endpoints; validate JSON against schemas.

Troubleshooting

- Compare the exact request: URL, method, headers, body, network path.
- 401 with no app logs: rejected earlier at the gateway, WAF or load balancer.
- Use curl -v and correlation IDs to follow a request.